Implementación de Infraestructura AAA Segura (Cisco IOS & Windows Server NPS)

Autor: Manuel Alejandro Cruz Messón
Matrícula: 2025-0689
Enlace del Video: https://youtu.be/mO1XfCYHmUE

1. Propósito del Laboratorio

El propósito fundamental de este laboratorio es diseñar, implementar y validar una arquitectura centralizada de **Control de Acceso, Autenticación, Autorización y Auditoría (AAA)** sobre dispositivos de red Cisco (Router y Switch), mitigando las vulnerabilidades inherentes a la gestión de credenciales locales dispersas y al acceso administrativo irrestricto.

A través de esta implementación se persiguen los siguientes fines específicos de seguridad:

- **Centralización de la Identidad Operativa:** Delegar el proceso de autenticación de los administradores y operadores a una infraestructura de identidad corporativa (**Active Directory** y **Windows Server NPS** vía protocolo **RADIUS**), facilitando el aprovisionamiento, la auditoría y la revocación inmediata de accesos desde un único punto de control.
- **Aplicación Estricta del Principio de Mínimo Privilegio (PoLP):** Romper la dicotomía tradicional de Cisco IOS (modo usuario nivel 1 vs. modo privilegiado nivel 15) mediante la fragmentación granular de permisos en niveles EXEC intermedios (**0, 5 y 10**), inyectados dinámicamente mediante atributos **VSA (Cisco-AVPair:** shell:priv-lvl=X**)** según el grupo de pertenencia del usuario.
- **Segregación y Blindaje de Perímetros de Acceso:** Restringir la autenticación centralizada RADIUS exclusivamente a los puertos de gestión física (consola y auxiliar), mientras que el acceso remoto a través de terminales virtuales (VTY) queda estrictamente confinado al servicio cifrado **SSH v2** con validación local independiente, previniendo la exposición remota de vectores de ataque hacia la consola física.
- **Garantía de Disponibilidad y Resiliencia Operativa:** Asegurar la continuidad de la gestión del equipamiento ante contingencias o fallos de conectividad con el servidor NPS/AD, mediante la configuración de un mecanismo de respaldo (*fallback*) con una cuenta local de nivel 15 debidamente protegida.
- **Trazabilidad y Rendición de Cuentas (Non-Repudiation):** Establecer un registro continuo de eventos de seguridad (syslog) que documente los intentos de inicio de sesión exitosos y fallidos (SEC_LOGIN), así como la contabilidad (*accounting*) del ciclo de vida de cada sesión de administración para fines de auditoría forense y cumplimiento normativo.

2. Resumen y Alcance del Laboratorio

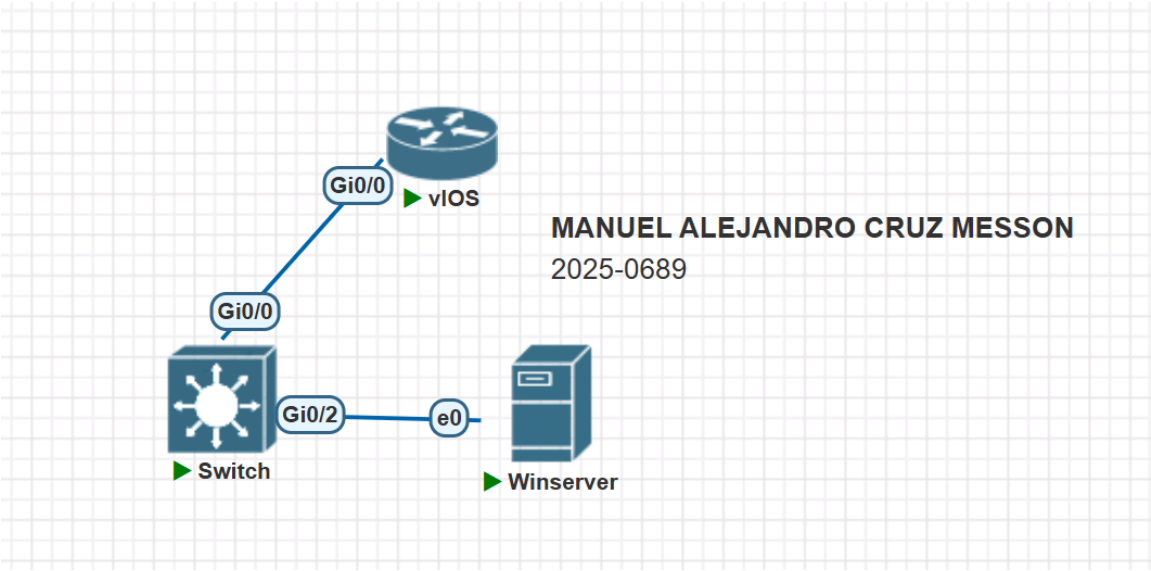
Este laboratorio implementa una solución integral de **Control de Acceso, Autenticación y Autorización (AAA)** corporativa para dispositivos de infraestructura de red Cisco (Router y Switch), centralizando la gestión de identidades en un servidor **Windows Server** mediante los roles de **Active Directory Domain Services (AD DS)** y **Network Policy Server (NPS / RADIUS)**.

Objetivos Clave Ejecutados:

1. **Centralización AAA en Puertos Físicos:** Aplicación estricta de autenticación y autorización RADIUS exclusivamente en las líneas físicas de consola (line con 0) y auxiliar (line aux 0).
2. **Control Granular por Niveles de Privilegio (VSA):** Asignación dinámica de niveles EXEC 0, 5 y 10 mediante atributos específicos de fabricante de Cisco (**Cisco-AVPair: shell:priv-lvl=X**), segmentando las funciones operativas según los grupos de seguridad en Active Directory.
3. **Resiliencia y Contingencia Local:** Integración de una cuenta local administrativa (admin) con nivel 15 de rescate en caso de indisponibilidad de la infraestructura RADIUS/AD.
4. **Administración Remota Segura (SSH):** Configuración de transporte seguro vía SSH v2 en las líneas de terminal virtual (line vty 0 15), desacopladas de las políticas de consola mediante autorización local independiente.
5. **Auditoría y Trazabilidad:** Registro en syslog de intentos de login exitosos y fallidos (SEC_LOGIN), y contabilidad de sesiones hacia NPS.

3. Topología de Red y Plan de Direccionamiento

La infraestructura se compone de un segmento de red de gestión local en Capa 2 y Capa 3 bajo el direccionamiento 10.25.68.0/27.



Matriz de Conectividad e Interfaces

Dispositivo	Rol de Red	Interfaz	Dirección IP / Máscara	Gateway Predeterminado
R1 (vIOS)	Router de Borde / Cliente RADIUS	GigabitEthernet0/0	10.25.68.1/27 (255.255.255.224)	N/A
SW1 (IOSvL2)	Switch de Acceso / Cliente RADIUS	Vlan1	10.25.68.2/27 (255.255.255.224)	10.25.68.1
Winserver	Controlador AD DS / Servidor NPS	Ethernet0	10.25.68.10/27 (255.255.255.224)	10.25.68.1

4. Matriz de Control de Privilegios y Comandos

El modelo de privilegios de Cisco IOS restringe el conjunto de comandos permitidos según el nivel inyectado por NPS:

Nivel de Privilegio	Rol Asignado	Grupo AD / Origen	Atributo VSA RADIUS	Comandos Autorizados en EXEC	Comandos Bloqueados / Restringidos
0	Restringido / Básico	Cisco-Priv-0	shell:priv-lvl=0	show privilege, exit, quit, logout, enable	ping, traceroute, show running-config, modos de configuración
5	Operativo / Diagnóstico	Cisco-Priv-5	shell:priv-lvl=5	ping, traceroute, show ip interface brief, show interfaces, show privilege	show running-config, show startup-config, configure terminal

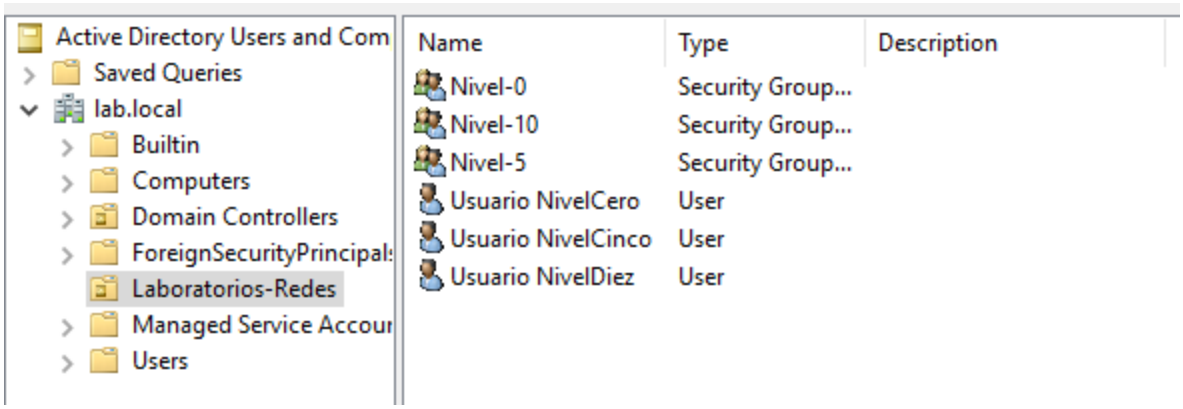
10	Auditoría y Red	Cisco-Priv-10	shell:priv-lvl=10	show running-config, show startup-config, show mac address-table, show vlan brief, show ip route	Modificaciones de configuración global (configure terminal)
15	Administrador de Rescate	Base de Datos Local (admin)	Fallback Local / Directo	Control total de comandos EXEC, modo privilegiado y configuración global	Ninguno

5. Implementación en Windows Server (AD DS & NPS)

5.1. Estructura de Active Directory

Se crearon tres grupos de seguridad globales para alojar las cuentas operativas:

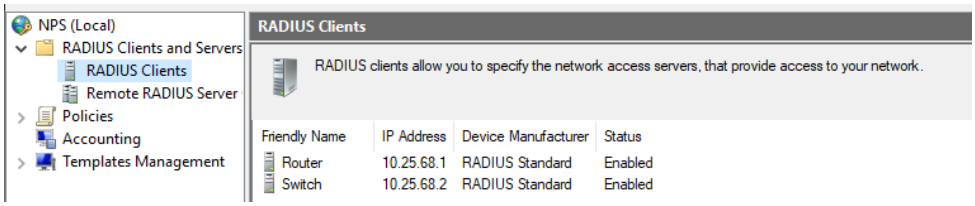
- Cisco-Priv-0 ➔ Usuario miembro: user-nivel0
- Cisco-Priv-5 ➔ Usuario miembro: user-nivel5
- Cisco-Priv-10 ➔ Usuario miembro: user-nivel10



5.2. Configuración del Servicio NPS (RADIUS)

- **Clientes RADIUS:** Se registraron tanto el Router (10.25.68.1) como el Switch (10.25.68.2) con la clave compartida (Shared Secret) configurada.
- **Políticas de Red (Network Policies):** Se construyeron políticas independientes evaluando la condición Windows Groups. En la sección **Settings ➔ Vendor Specific**, se definió el atributo de Cisco:

- **Código Vendor:** 9 (Cisco)
- **Nombre de Atributo:** Cisco-AVPair
- **Valor:** shell:priv-lvl=10 (adaptado según la directiva para 0, 5 y 10)



7. Pruebas y Evidencias de Validación

7.1. Verificación de Nivel 0 (Modo Restringido)

- **Objetivo:** Verificar que el usuario inicia con prompt de usuario (>), obtiene nivel 0 y se le deniegan comandos operativos.
- **Comandos probados:** show privilege, ping 10.25.68.10, exit.

```
User Access Verification

Username: user-nivel0
Password:

**************************************************************************
* IOSv is strictly limited to use for evaluation, demonstration and IOS  *
* education. IOSv is provided as-is and is not supported by Cisco's      *
* Technical Advisory Center. Any use or disclosure, in whole or in part, *
* of the IOSv Software or Documentation to any third party for any       *
* purposes is expressly prohibited except as otherwise authorized by     *
* Cisco in writing.                                                      *
**************************************************************************
R1>
*Oct 29 18:26:31.813: %SEC_LOGIN-5-LOGIN_SUCCESS: Login Success [user: user-nivel0] [Source: UNKNOWN] [lo
calport: 0] at 18:26:31 UTC Thu Oct 29 2026
R1>show privilege
Current privilege level is 0
R1>ping 10.25.68.10
   ^
% Invalid input detected at '^' marker.

R1>
```

7.2. Verificación de Nivel 5 (Diagnóstico / Operativo)

- **Objetivo:** Validar inicio directo en modo EXEC (#), autorización de utilidades de conectividad y restricción de configuraciones.
- **Comandos probados:** show privilege, ping 10.25.68.10, show ip interface brief, intento denegado de show running-config.

```
**************************************************************************
R1#
*Oct 29 18:27:16.413: %SEC_LOGIN-5-LOGIN_SUCCESS: Login Success [user: user-nivel5] [Source: UNKNOWN] [lo
calport: 0] at 18:27:16 UTC Thu Oct 29 2026show privilege
Current privilege level is 5
R1#ping 10.25.68.10
Type escape sequence to abort.
Sending 5, 100-byte ICMP Echos to 10.25.68.10, timeout is 2 seconds:
!!!!!
Success rate is 100 percent (5/5), round-trip min/avg/max = 2/3/5 ms
R1#show runn
R1#show running-config
          ^
% Invalid input detected at '^' marker.

R1#
```

```
R1#show interfaces
GigabitEthernet0/0 is up, line protocol is up
  Hardware is iGbE, address is 5076.db00.1800 (bia 5076.db00.1800)
  Description: LAN-SERVIDORES
  Internet address is 10.25.68.1/27
  MTU 1500 bytes, BW 1000000 Kbit/sec, DLY 10 usec,
     reliability 255/255, txload 1/255, rxload 1/255
  Encapsulation ARPA, loopback not set
  Keepalive set (10 sec)
  Full Duplex, 1Gbps, link type is auto, media type is RJ45
  output flow-control is unsupported, input flow-control is unsupported
  ARP type: ARPA, ARP Timeout 04:00:00
  Last input 00:00:00, output 00:00:00, output hang never
  Last clearing of "show interface" counters never
  Input queue: 0/75/0/0 (size/max/drops/flushes); Total output drops: 0
  Queueing strategy: fifo
  Output queue: 0/40 (size/max)
  5 minute input rate 0 bits/sec, 0 packets/sec
  5 minute output rate 0 bits/sec, 0 packets/sec
     947 packets input, 83902 bytes, 0 no buffer
     Received 31 broadcasts (0 IP multicasts)
     0 runts, 0 giants, 0 throttles
     0 input errors, 0 CRC, 0 frame, 0 overrun, 0 ignored
     0 watchdog, 0 multicast, 0 pause input
     525 packets output, 43926 bytes, 0 underruns
```

```
*Oct 29 18:34:54.206: %SEC_LOGIN-5-LOGIN_SUCCESS: Login Success [user: user-niv
15] [Source: UNKNOWN] [localport: 0] at 18:34:54 UTC Thu Oct 29 2026
SW1#show ma
SW1#show mac ?
% Unrecognized command
SW1#show interfaces
GigabitEthernet0/0 is up, line protocol is up (connected)
  Hardware is iGbE, address is 5049.4b00.1900 (bia 5049.4b00.1900)
  Description: ENLACE-ROUTER
  MTU 1500 bytes, BW 1000000 Kbit/sec, DLY 10 usec,
     reliability 255/255, txload 1/255, rxload 1/255
  Encapsulation ARPA, loopback not set
  Keepalive set (10 sec)
  Auto Duplex, Auto Speed, link type is auto, media type is RJ45
  output flow-control is unsupported, input flow-control is unsupported
  ARP type: ARPA, ARP Timeout 04:00:00
  Last input 00:00:03, output 00:00:00, output hang never
  Last clearing of "show interface" counters never
  Input queue: 0/75/0/0 (size/max/drops/flushes); Total output drops: 0
  Queueing strategy: fifo
  Output queue: 0/0 (size/max)
  5 minute input rate 0 bits/sec, 0 packets/sec
  5 minute output rate 0 bits/sec, 0 packets/sec
     674 packets input, 57522 bytes, 0 no buffer
     Received 34 broadcasts (34 multicasts)
     0 runts, 0 giants, 0 throttles
     0 input errors, 0 CRC, 0 frame, 0 overrun, 0 ignored
     0 watchdog, 34 multicast, 0 pause input
     1732 packets output, 140994 bytes, 0 underruns
 --More--
```

7.3. Verificación de Nivel 10 (Auditoría y Gestión)

- **Objetivo:** Demostrar acceso a configuraciones activas y tablas de conmutación de Capa 2.
- **Comandos probados:** show privilege, show ip route, show mac address-table

```
*Oct 29 18:36:35.323: %SEC_LOGIN-5-LOGIN_SUCCESS: Login Success [user: user-nivel10] [Source: UNKNOWN] [l
ocalport: 0] at 18:36:35 UTC Thu Oct 29
R1#show privilege
Current privilege level is 10
R1#show ip rout
R1#show ip route
Codes: L - local, C - connected, S - static, R - RIP, M - mobile, B - BGP
       D - EIGRP, EX - EIGRP external, O - OSPF, IA - OSPF inter area
       N1 - OSPF NSSA external type 1, N2 - OSPF NSSA external type 2
       E1 - OSPF external type 1, E2 - OSPF external type 2
       i - IS-IS, su - IS-IS summary, L1 - IS-IS level-1, L2 - IS-IS level-2
       ia - IS-IS inter area, * - candidate default, U - per-user static route
       o - ODR, P - periodic downloaded static route, H - NHRP, l - LISP
       a - application route
       + - replicated route, % - next hop override, p - overrides from PfR

Gateway of last resort is not set

      10.0.0.0/8 is variably subnetted, 2 subnets, 2 masks
C        10.25.68.0/27 is directly connected, GigabitEthernet0/0
L        10.25.68.1/32 is directly connected, GigabitEthernet0/0
R1#
```

```
*Oct 29 18:37:19.226: %SEC_LOGIN-5-LOGIN_SUCCESS: Login Success [user: user-nive
l10] [Source: UNKNOWN] [localport: 0] at 18:37:19 UTC Thu Oct 29 2026how
% Type "show ?" for a list of subcommands
SW1#
SW1#show privilege
Current privilege level is 10
SW1#show ma
SW1#show m?
mab         mac     management  mdns
mediatrace  memory  modemcap    monitor
mpls        mtm     mvpn

SW1#show mac ad
SW1#show mac address-table
          Mac Address Table
-------------------------------------------

Vlan    Mac Address       Type        Ports
----    -----------       --------    -----
   1    5070.b200.1a00    DYNAMIC     Gi0/2
   1    5076.db00.1800    DYNAMIC     Gi0/0
   1    925d.c9e8.f98b    DYNAMIC     Gi0/2
Total Mac Addresses for this criterion: 3
```

7.4. Verificación de Fallback y Contingencia Local (admin)

- **Objetivo:** Validar que el usuario local admin inicia sesión directamente en nivel 15 sin degradación ante fallos del canal RADIUS.
- **Comando probado:** show privilege.

```
User Access Verification

Username: admin
Password:

**************************************************************************
* IOSv is strictly limited to use for evaluation, demonstration and IOS  *
* education. IOSv is provided as-is and is not supported by Cisco's      *
* Technical Advisory Center. Any use or disclosure, in whole or in part, *
* of the IOSv Software or Documentation to any third party for any       *
* purposes is expressly prohibited except as otherwise authorized by     *
* Cisco in writing.                                                      *
**************************************************************************
R1#
*Oct 29 18:38:54.346: %SEC_LOGIN-5-LOGIN_SUCCESS: Login Success [user: admin] [Source: UNKNOWN] [localpor
t: 0] at 18:38:54 UTC Thu Oct 29 2026
R1#show privilege
Current privilege level is 15
R1#
```

7.5. Verificación de Acceso Remoto por SSH

- **Objetivo:** Confirmar que las líneas virtuales VTY utilizan transporte SSH v2 con autenticación local independiente.
- **Comando probado:** Conexión desde PowerShell con ssh admin@10.25.68.2.

```
PS C:\Users\Administrator> ssh admin@10.25.68.2

IOSv - Cisco Systems Confidential -

Supplemental End User License Restrictions

This IOSv software is provided AS-IS without warranty of any kind. Under no circumstances may this software be used sepa
rate from the Cisco Modeling Labs Software that this software was provided with, or deployed or used as part of a produc
tion environment.

By using the software, you agree to abide by the terms and conditions of the Cisco End User License Agreement at http://
www.cisco.com/go/eula. Unauthorized use or distribution of this software is expressly prohibited.
Password:

IOSv - Cisco Systems Confidential -

Supplemental End User License Restrictions

This IOSv software is provided AS-IS without warranty of any kind. Under no circumstances may this software be used sepa
rate from the Cisco Modeling Labs Software that this software was provided with, or deployed or used as part of a produc
tion environment.

By using the software, you agree to abide by the terms and conditions of the Cisco End User License Agreement at http://
www.cisco.com/go/eula. Unauthorized use or distribution of this software is expressly prohibited.

SW1#
```

```
*Oct 29 18:38:42.506: %SYS-6-LOGOUT: User user-nivel10 has exited tty session 0(
)
*Oct 29 18:40:19.254: %SEC_LOGIN-5-LOGIN_SUCCESS: Login Success [user: admin] [S
ource: 10.25.68.10] [localport: 22] at 18:40:19 UTC Thu Oct 29 2026
```

7.6. Auditoría de Eventos y Trazabilidad (Syslog)

- **Objetivo:** Constatar la generación de eventos de auditoría para accesos por consola física (puerto 0) y remotos (puerto 22).
- **Comando probado:** show logging | include %SEC_LOGIN.

```
SW1#show logging | include %SEC_LOGIN.
*Oct 29 18:24:37.977: %SEC_LOGIN-4-LOGIN_FAILED: Login failed [user: ] [Source: UNKNOWN] [localport: 0] [Reason: Login
 Authentication Failed] at 18:24:37 UTC Thu Oct 29 2026
*Oct 29 18:25:57.261: %SEC_LOGIN-5-LOGIN_SUCCESS: Login Success [user: admin] [Source: UNKNOWN] [localport: 0] at 18:2
5:57 UTC Thu Oct 29 2026
*Oct 29 18:34:54.206: %SEC_LOGIN-5-LOGIN_SUCCESS: Login Success [user: user-nivel5] [Source: UNKNOWN] [localport: 0] a
t 18:34:54 UTC Thu Oct 29 2026
*Oct 29 18:37:19.226: %SEC_LOGIN-5-LOGIN_SUCCESS: Login Success [user: user-nivel10] [Source: UNKNOWN] [localport: 0]
at 18:37:19 UTC Thu Oct 29 2026
*Oct 29 18:40:19.254: %SEC_LOGIN-5-LOGIN_SUCCESS: Login Success [user: admin] [Source: 10.25.68.10] [localport: 22] at
 18:40:19 UTC Thu Oct 29 2026
*Oct 29 18:41:04.453: %SEC_LOGIN-5-LOGIN_SUCCESS: Login Success [user: admin] [Source: UNKNOWN] [localport: 0] at 18:4
1:04 UTC Thu Oct 29 2026
SW1#
```

8. Conclusiones

1. **Principio de Mínimo Privilegio:** La fragmentación en niveles 0, 5 y 10 demostró que es viable confinar a los operadores de red a sus tareas específicas sin otorgar acceso global nivel 15, minimizando el impacto de errores humanos o compromisos de cuentas.
2. **Centralización Eficiente:** La integración con Windows Server NPS elimina la necesidad de crear y mantener credenciales estáticas en cada conmutador y enrutador, facilitando el aprovisionamiento, rotación de credenciales y revocación de accesos desde Active Directory.
3. **Resiliencia Operativa:** La correcta delimitación de listas AAA garantiza que los mecanismos centralizados no comprometan la disponibilidad del equipamiento, preservando canales de contingencia local ante incidentes de conectividad.

Declaración de Uso de Inteligencia Artificial

Herramientas utilizadas: Modelos de lenguaje e inteligencia artificial generativa asistieron en la consulta de sintaxis, estructuración de archivos de configuración y formateo de la documentación técnica.

Alcance del uso: La herramienta sirvió de soporte técnico para la redacción y resolución de incompatibilidades de entorno.

Autoría y validación: El diseño topológico, la implementación en laboratorio, el enrutamiento y aprovisionamiento en Cisco IOS, la parametrización gráfica de políticas y VPN en FortiOS, y las pruebas de auditoría fueron configuradas, probadas y validadas íntegramente por el autor del proyecto.